

Security Incident Report

Report ID	CLD-IR- 0001
Related ticket	CLD-IR-0001
Report title	CLD-IR-0001- <i>Suspicious sign-in activity: daniel.reeve@cloudora.io</i>
Analyst	Simon Agpoon
Date of report (UTC)	Aug 10, 2026
Incident severity	P1: CEO account compromised. The attacker registered an unauthorized MFA device and set an inbox rule to suppress financial communications.
Status	Contained. Active sessions revoked, MFA device removed/credentials reset, mailbox rule deleted, and attacker IP blocked. Accounts remain under monitoring
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Following a password spray attack from Lagos-based IPs, an attacker compromised the Microsoft 365 accounts of CEO Daniel Reeve and Priya Nair. The actor registered a MFA device on a Pixel 6, accessed Outlook Web and the Azure Portal, created a malicious inbox rule to hide financial emails, and accessed SharePoint via Priya's account.

An impossible travel alert at 08:41 UTC triggered by Daniel's legitimate London login prompted immediate SOC response. Containment actions included revoking active sessions and tokens, removing the rogue MFA device and inbox rule, resetting credentials, and blocking the attacker IPs. A separate Dubai travel alert for Omar Farah was investigated and cleared as legitimate business activity.

2. Incident timeline

Time (UTC)	Source	Event	Evidence / notes
Aug 8, 00:07 to 04:58	Sign-in logs	Password spray begins	Multiple accounts targeted from 102.89.44.17, 102.89.44.23, and 102.89.45.101 (Lagos, Nigeria). ResultType 50126 (invalid credentials), User-Agent: Windows 10 / Chrome 125. 44 failed attempts recorded.
Aug 8, 2:22:31	Sign-in logs	CEO targeted	Failed authentication for daniel.reeve@cloudora.io from 102.89.45.101, Lagos. ResultType 50126.
Aug 8, 3:16:43	Sign-in logs	Priya targeted	Failed authentication for priya.nair@cloudora.io from 102.89.44.17, Lagos. ResultType 50126.

Aug 9, 00:14 to 04:50	Sign-in logs	Password spray continues	Targeted attempts against multiple Cloudora accounts from 102.89.x.x pool. ResultType 50126.
Aug 9 to 10, 01:57 to 03:09	Sign-in logs	CEO targeted again	3 failed authentication attempts for Daniel Reeve from 102.89.45.101. ResultType 50126.
Aug 10, 3:12:05	Sign-in logs	CEO account compromised	Successful M365 authentication for daniel.reeve@cloudora.io from 102.89.44.17, Lagos, Windows 10 / Chrome 125. ResultType 0.
Aug 10, 3:14:30	Sign-in logs	CEO mailbox accessed	Successful Outlook Web access from 102.89.44.17. ResultType 0.
Aug 10, 3:26:02	Sign-in logs	Azure Portal accessed	Successful Azure Portal access via Daniel's session from 102.89.44.17. ResultType 0.
Aug 10, 3:31:09	Audit logs	Malicious inbox rule created	Created rule "RSS Subscriptions" redirecting emails from finance@cloudora.io or containing "invoice" to RSS Feeds folder and marking as read. Result: Success.
Aug 10, 3:44:55	Sign-in logs	Priya login attempt	Failed authentication for priya.nair@cloudora.io from 102.89.45.101, Lagos. ResultType 50126.
Aug 10, 3:47:18	Sign-in logs	Priya account compromised	Successful M365 authentication for priya.nair@cloudora.io from 102.89.45.101, Lagos, Windows 10 / Chrome 125. ResultType 0.
Aug 10, 3:52:40	Sign-in logs	SharePoint accessed	Successful SharePoint Online session initiated using Priya's account from 102.89.45.101. ResultType 0.
Aug 10, 6:15:22	Sign-in logs	Omar Farah sign-in	Successful login for omar.farah@cloudora.io from 185.93.245.66 (Dubai, UAE),

			<i>macOS / Safari. ResultType 0. Confirmed legitimate travel.</i>
<i>Aug 10, 7:31:11</i>	<i>Sign-in logs</i>	<i>Priya legitimate activity</i>	<i>Successful login from 203.0.113.10 (London, UK), iOS 17 / Mobile Safari. ResultType 0. Confirmed user baseline.</i>
<i>Aug 10, 8:41:00</i>	<i>Sign-in logs</i>	<i>CEO legitimate activity</i>	<i>Successful login from 203.0.113.11 (London, UK), macOS 14 / Safari 17. ResultType 0. Triggered impossible travel detection against 03:12:05 UTC Lagos session.</i>

3. Findings

Finding 1: Distributed Password-Spray Campaign

- Multiple Cloudora corporate accounts were targeted by credential guessing from Lagos, Nigeria-based IP space.
- *Evidence:* Entra ID sign-in logs recorded 44 ResultType 50126 failures originating from 102.89.44.17, 102.89.44.23, and 102.89.45.101 between August 8 and August 10.
- *Impact:* Enabled initial credential validation leading directly to the compromise of two user accounts.

Finding 2: CEO Account Takeover

- Daniel Reeve's M365 account was breached via valid credentials from an attacker-controlled Lagos IP.
- *Evidence:* Sign-in logs showed authentication failures at 03:09:12 and 03:10:41 UTC, immediately followed by a successful sign-in (ResultType 0) at 03:12:05 UTC from 102.89.44.17 (Windows 10 / Chrome 125).
- *Impact:* Unauthorized access to the executive corporate identity.

Finding 3: Mailbox Access and Reconnaissance

- The attacker accessed the CEO's Outlook Web application.
- *Evidence:* Entra ID sign-in logs recorded successful interactive access to AppId OfficeHome / Outlook Web at 03:14:30 UTC from 102.89.44.17.

- *Impact:* Direct exposure of confidential executive email communications.

Finding 4: MFA Persistence Established

- The attacker registered an unauthorized secondary MFA device to ensure persistent access.
- *Evidence:* Audit logs show a User registered security info success event at 03:18:44 UTC from 102.89.44.17, binding a Microsoft Authenticator instance on a Google Pixel 6.
- *Impact:* Bypassed future single-factor prompts, maintaining persistence independent of potential password resets without session clearing.

Finding 5: Cloud Resource Exploration via Azure Portal

- Daniel Reeve's session was used to interact with the Azure portal.
- *Evidence:* Sign-in logs captured successful access to the Azure Portal service (ResultType 0) at 03:26:02 UTC from 102.89.44.17.
- *Impact:* Risk of unauthorized visibility into cloud directory roles, subscriptions, and internal infrastructure.

Finding 6: Malicious Inbox Rule for BEC Staging

- The attacker created a mailbox rule to suppress billing and payment notifications.
- *Evidence:* Exchange audit logs recorded New-InboxRule at 03:31:09 UTC named "RSS Subscriptions", configured to move messages containing "invoice" or sent from finance@cloudora.io to the RSS Feeds folder and mark them as read.
- *Impact:* Staging for business email compromise and diversion of financial alerts to avoid victim discovery.

Finding 7: Account Compromise of Priya Nair

- Priya Nair's account was compromised from the same Lagos infrastructure.
- *Evidence:* Sign-in logs showed a failed login at 03:44:55 UTC, followed by a successful authentication (ResultType 0) at 03:47:18 UTC from 102.89.45.101.

- *Impact*: Lateral exposure and expansion of the threat actor's tenant footprint.

Finding 8: SharePoint Online Data Access

- Priya Nair's compromised identity was leveraged to access internal document stores.
- *Evidence*: Sign-in and audit logs documented access to SharePoint Online at 03:52:40 UTC from 102.89.45.101.
- *Impact*: Potential reconnaissance or staging of sensitive corporate documentation.

Finding 9: Cleared False Positive: Omar Farah (Dubai Sign-in)

- Sign-in activity for Omar Farah from Dubai, UAE was reviewed and verified as legitimate authorized travel.
- *Evidence*: checked omar.farah@cloudora.io and found 12 successful logins from Dubai (185.93.245.66) between August 8 and August 10. All logins happened during normal daytime hours (09:00 to 19:00), succeeded on the first attempt with zero failures, and used his normal iPhone (iOS 17 / Mobile Safari) that matches his London baseline. This confirmed legitimate business travel and ruled out an account takeover.
- *Impact*: Differentiates benign user mobility from the attacker's simultaneous Lagos campaign.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IP Address	102.89.44.17	Aug 8, 0:07	Password spray; Daniel Reeve compromise, OWA access, MFA addition, Azure Portal, and inbox rule setup.
IP Address	102.89.44.23	Aug 8, 0:15	Password spray origin across Cloudora user accounts.
IP Address	102.89.45.101	Aug 8, 0:22	Password spray; Priya Nair compromise and SharePoint Online access.

<i>User-Agent Profile</i>	<i>Windows 10 / Chrome 125</i>	<i>Aug 8, 0:07</i>	<i>Consistent client fingerprint across all malicious authentication events.</i>
<i>Device / MFA</i>	<i>Google Pixel 6 / Authenticator</i>	<i>Aug 10, 3:18</i>	<i>Unauthorized MFA method bound to daniel.reeve@cloudora.io.</i>
<i>Exchange Rule Name</i>	<i>RSS Subscriptions</i>	<i>Aug 10, 3:31</i>	<i>Malicious inbox rule filtering finance@cloudora.io and keyword "invoice".</i>

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
<i>Credential Access</i>	<i>T1110.003</i>	<i>Password Spraying</i>	<i>High-volume failed logins (50126) across 26 targeted accounts from 102.89.x.x subnets (Finding 1).</i>
<i>Initial Access</i>	<i>T1078.004</i>	<i>Valid Accounts: Cloud Accounts</i>	<i>Successful logins using valid credentials for Daniel Reeve and Priya Nair (Findings 2, 7).</i>
<i>Persistence</i>	<i>T1098.005</i>	<i>Account Manipulation: Device Registration</i>	<i>Attacker registered a Pixel 6 Authenticator app to Daniel's Entra ID profile (Finding 4).</i>
<i>Collection</i>	<i>T1114.002</i>	<i>Email Collection: Remote Email Collection</i>	<i>Direct interactive mailbox access via Outlook Web on the CEO account (Finding 3).</i>
<i>Collection</i>	<i>T1213.002</i>	<i>Data from Information Repositories: SharePoint</i>	<i>Unauthorized access to corporate SharePoint repository via Priya's session (Finding 8).</i>
<i>Defense Evasion</i>	<i>T1564.008</i>	<i>Hide Artifacts: Email Hiding Rules</i>	<i>Malicious rule "RSS Subscriptions" moving financial emails to RSS Feeds folder and marking as read (Finding 6).</i>

6. Scope

Accounts confirmed compromised

- daniel.reeve@cloudora.io (CEO): Account taken over; mailbox accessed; rogue MFA enrolled; BEC rule staged.
- priya.nair@cloudora.io: Account taken over; SharePoint Online environment accessed.

Accounts targeted but not breached

- 24 Cloudora accounts targeted during password spray attack
- All attempts on these accounts failed in 50126; no attacker logins

Accounts investigated and cleared (false positives)

- omar.farah@cloudora.io: Sign-ins from 185.93.245.66 (Dubai, UAE) flagged due to geographic anomaly were cleared based on baseline from Dubai(12 successful logins between August 8 and August 10 from same IP)

7. Actions taken

What was actually done, by whom, at what time (UTC), in order. Containment first (stop the bleeding), then eradication (remove attacker access and persistence), then verification (prove it worked). An action without a timestamp did not happen.

Time (UTC)	Action	Performed by	Verified how
Aug 10, 8:55	Revoked all active user sessions and refresh tokens for Daniel Reeve and Priya Nair.	SOC Analyst	Queried Entra ID active session logs; confirmed existing tokens invalidated.
Aug 10, 8:58	Purged rogue Google Pixel 6 MFA registration from Daniel Reeve's authentication methods.	SOC Analyst	Verified Entra ID Authentication Methods blade; only corporate hardware tokens remain.
Aug 10, 9:05	Force-reset passwords and re-enrolled MFA for Daniel Reeve and Priya Nair.	SOC Analyst	Validated self-service password reset logs and successful re-enrollment via verified out-of-band contact.
Aug 10, 9:12	Deleted malicious Exchange inbox rule "RSS Subscriptions" from Daniel Reeve's mailbox.	SOC Analyst	Executed Get-InboxRule - Mailbox daniel.reeve via Exchange Online PowerShell; verified rule is absent.
Aug 10, 9:18	Applied tenant-wide Conditional Access block on attacker IPs: 102.89.44.17, 102.89.44.23, 102.89.45.101.	SOC Analyst	Tested authentication via test harness against blocked IPs; confirmed 53003 block code.
Aug 10, 9:30	Initiated mandatory password rotation for all 24 spray-targeted accounts.	SOC Analyst	Monitored Entra ID admin audit logs confirming password reset flags dispatched.
Aug 10, 9:45	Established heightened SIEM alerting and post-incident monitoring.	SOC Analyst	Monitored real-time auth stream; verified zero connections from malicious IP pool or device fingerprints.

Aug 10, 8:55	Revoked all active user sessions and refresh tokens for Daniel Reeve and Priya Nair.	SOC Analyst	Queried Entra ID active session logs; confirmed existing tokens invalidated.
--------------	--	-------------	--

8. Recommendations

Quick Wins

- Enable password-spray detection and automatic blocking. (Finding 1)
- Require phishing-resistant MFA for sensitive and executive accounts. (Findings 2, 4, 7)
- Restrict and alert on new MFA device registrations. (Finding 4)
- Alert on suspicious mailbox rule creation and financial keyword forwarding. (Finding 6)

Strategic Changes

- Use Conditional Access to block high-risk locations, unmanaged devices, and untrusted IPs. (Findings 2, 7)
- Enforce automated step-up policies for impossible travel and anomalous sign-ins. (Findings 2, 5, 7, 8)
- Apply least-privilege access and device compliance policies to SharePoint and sensitive cloud resources. (Findings 5, 8)

9. Lessons learned

What worked: Comprehensive Entra ID sign-in logs and Microsoft 365 audit logs allowed the SOC to reconstruct attacker movements, including the MFA device registration, malicious inbox rule creation, and SharePoint access.

What was slow/missing: Password-spray attempts persisted across multiple days before an impossible travel alert initiated triage, giving the attacker time to establish persistence.

What should improve: Implement earlier detections and automated containment for distributed password sprays, out-of-band MFA method additions, and suspicious inbox rule changes to reduce response time.